Security memo

EcoCharge Fleet Dashboard

This is an eco-charging dashboard which is static based on the data from the demo cars. There are two risks associated with the deployment of EcoCharge identified below.

Cross-site scripting (XSS) could arise if future vehicle names or other external data were inserted as HTML. An attacker could inject JavaScript, change fleet information, or display misleading charging estimates. The current application reduces this risk by building text with textContent rather than interpreting it as HTML. We would retain this approach, validate incoming data against expected types and permitted values, and review any future HTML rendering before release. Input validation alone would not replace safe output handling.

Insecure HTTP delivery would become a vulnerability if the dashboard were published without HTTPS. A network attacker could modify the JavaScript or vehicle data in transit, changing battery statuses, calculation results, or instructions shown to managers. We would serve the deployed dashboard and its resources through HTTPS to protect their integrity during transmission. The current offline version loads local files, so this transport risk applies to online hosting rather than local use.

Together, these controls support trustworthy fleet information and cost estimates. Any future data integration or hosting change should trigger another security review before managers rely on the dashboard.

Sources

- OWASP Input Validation Cheat Sheet, course-provided copy: Input Validation Strategies and Common Pitfalls.
- Snyk Secure Coding Practices, course-provided copy: Automated scanning and code reviews, and encryption guidance.
- ICS432 Assignment 2 brief, page 4: Security Risk Assessment and HTTPS mitigation example. Application evidence: fleet.js and calculator.js from EcoCharge_Fleet.zip.